

Configuration Management (3.4) Family

Security Requirements and the Technologies That Implement Them

A practitioner reference for Defense Industrial Base contractors · Family 4 of 14 in a 14-part series on the NIST SP 800-171 families · Prepared July 2026

Overview of the Configuration Management Family

Configuration Management (3.4) governs the **known-good state** of every system in the CUI environment: what a system is supposed to look like (baselines), how it is allowed to change (change control with security impact analysis), and what it is allowed to run (least functionality and software allowlisting). Where Access Control decides who gets in, this family decides what the environment itself is - and whether you can prove any given machine still matches its approved configuration.

The family contains **9 security requirements** - **2 Basic** (from FIPS 200) and **7 Derived** (from NIST SP 800-53). Six of the nine are weighted at the maximum **5 SPRS points**, making 3.4 one of the most point-dense families per requirement: an unimplemented family costs 33 points. In practice it is also one of the most labor-saving to automate - a hardened baseline deployed through Intune or GPO, an application-control policy, and an automated inventory together cover most of the family. This is **Family 4 of 14** in a planned series covering all fourteen 800-171 families.

Which revision applies? This guide covers **NIST SP 800-171 Revision 2**, which is the baseline the DoD's CMMC program and DFARS 252.204-7012 currently require. Revision 3 has **not** been adopted for CMMC as of this writing - continue to assess against Revision 2 until the DoD formally transitions.

Requirement wording below is **summarized for readability**. The controlling text is the official publication, **NIST SP 800-171 Rev 2** (security requirements) and **NIST SP 800-171A** (assessment objectives); consult them for exact language. SPRS point values are per the **DoD Assessment Methodology** (NIST SP 800-171 DoD Assessment Methodology, Version 1.2.1).

The 9 Configuration Management Requirements and Expected Evidence

The evidence column lists the artifacts an assessor typically expects; most controls need **both** a written policy and a technical artifact. The figure under each control ID is its **SPRS point value** (5, 3, or 1) - the score deducted if the control is not met.

NIST SP 800-171 Rev 2 Configuration Management (3.4) requirements, SPRS weight, and expected evidence.

Control	Security Requirement	Evidence / Artifacts an Assessor Expects
3.4.1 5 pts	Establish and maintain baseline configurations and inventories of organizational systems (including hardware, software, firmware, and documentation) throughout the respective system development life cycles.	A configuration management policy; a documented baseline for each system type that states which benchmark it follows (CIS, STIG, or Microsoft) and lists any approved deviations; dated hardware and software inventory exports; records showing baselines are periodically reviewed and updated
3.4.2 5 pts	Establish and enforce security configuration settings for information technology products employed in organizational systems.	A hardening-standard document that identifies the specific benchmark and version the organization has adopted (e.g., "CIS Microsoft Windows 11 Benchmark v3.0, Level 1"); exports of the Intune configuration profiles or GPOs that push those settings to systems; compliance-scan results (SCAP/SCC, CIS-CAT) proving the settings are actually applied, not just documented
3.4.3 1 pt	Track, review, approve or disapprove, and log changes to organizational systems.	A written change management procedure; the change control board (CCB) charter and its meeting minutes; sample change tickets showing each stage - request, review, approval or rejection, and implementation; a documented emergency-change procedure
3.4.4 1 pt	Analyze the security impact of changes prior to implementation.	A security impact analysis (SIA) field or checklist built into the change ticket itself; completed SIAs from recent changes; evidence that high-impact changes were tested or security-reviewed before they were deployed
3.4.5 5 pts	Define, document, approve, and enforce physical and logical access restrictions associated with changes to organizational systems.	A documented list of the roles and users authorized to make system changes; exports of privileged-group memberships showing only those people hold the rights; records of who is delegated rights to edit GPOs or Intune profiles; server-room or rack badge/key access logs; evidence that standard workstations are locked down against configuration changes
3.4.6 5 pts	Employ the principle of least functionality by configuring organizational systems to provide only essential capabilities.	A least-functionality standard defining which capabilities are essential; baseline documentation showing which services, features, and protocols are disabled (e.g., SMBv1, legacy TLS); the host firewall policy; port/service scan results reconciled against the approved list

Control	Security Requirement	Evidence / Artifacts an Assessor Expects
3.4.7 5 pts	Restrict, disable, or prevent the use of nonessential programs, functions, ports, protocols, and services.	A documented list separating essential from nonessential programs, ports, protocols, and services; the GPO/Intune profiles and firewall rules that disable the nonessential ones; records showing the list is periodically reviewed; scan results confirming restricted ports and services are actually closed
3.4.8 5 pts	Apply deny-by-exception (blacklisting) policy to prevent the use of unauthorized software or deny-all, permit-by-exception (whitelisting) policy to allow the execution of authorized software.	An application-control policy; the enforced AppLocker/WDAC policy exported as XML (or the configuration of a third-party allowlisting tool); the approved-software list with a named business owner for each title; block-event logs showing unauthorized software is actually being stopped
3.4.9 1 pt	Control and monitor user-installed software.	A policy governing what software users may install; evidence that standard users do not have local admin rights; the configuration of a self-service catalog (e.g., Intune Company Portal) for pre-approved installs; software-inventory diffs or alerts showing new installations are detected and reviewed

2 Basic requirements (3.4.1-3.4.2) and 7 Derived requirements (3.4.3-3.4.9). Under CMMC scoring rules (32 CFR 170.21) only requirements weighted at 1 point may be placed on a POA&M at assessment (with a narrow exception for 3.13.11) - so only the three 1-point requirements (3.4.3, 3.4.4, and 3.4.9) are POA&M-eligible, and the six 5-point requirements (3.4.1, 3.4.2, and 3.4.5-3.4.8) must be implemented before the assessment, making 3.4 one of the costliest families to leave unimplemented.

Six 5-point requirements. 3.4.1, 3.4.2, and 3.4.5 through 3.4.8 each carry a 5-point SPRS deduction, and under the CMMC Level 2 rules (32 CFR 170.21) a POA&M at assessment time may only contain 1-point requirements (with a single 3-point exception for 3.13.11). A 5-point requirement **cannot remain on a POA&M** - all six must be fully implemented before the assessment, not planned. Baselines, change-access restrictions, least functionality, and application control are the heart of the family; there is no deferring them to a remediation plan.

Implementing Technologies and How to Configure Them

The systems below are the common building blocks for the family. The pattern that works: pick an authoritative benchmark, deploy it through your management plane (Intune or GPO), verify it with a scanner, control drift through change management, and constrain what can run and what can be installed.

Security Baselines (CIS Benchmarks, DISA STIGs, Microsoft Security Baselines)

- Adopt one benchmark family per platform and name it (with version) in your hardening standard: **CIS Benchmarks** (Level 1 profile is the pragmatic start), **DISA STIGs** (stricter, DoD-native, natural for contractors already living in the DoD ecosystem), or **Microsoft Security Baselines** (lowest-effort for Windows/Edge/M365 Apps). (3.4.1, 3.4.2)
- Document deviations: every setting you relax from the benchmark gets a one-line justification and an approval. The benchmark + deviation register *is* the baseline document assessors ask for. (3.4.1)
- Cover every platform type in scope - Windows clients and servers, macOS (CIS or the macOS Security Compliance Project), Linux, network devices (DISA STIGs, CIS), hypervisors, and mobile (via MDM policy). (3.4.1, 3.4.2)
- Review baselines on a defined cadence (annually, and on OS version changes) through the change process, and version the baseline documents. (3.4.1, 3.4.3)

Baseline Deployment via Intune and Group Policy

- **Microsoft Intune** - deploy Microsoft Security Baselines natively (Endpoint security > Security baselines), or implement CIS/STIG settings via the settings catalog; use compliance policies plus Conditional Access to block non-compliant devices from CUI resources. (3.4.2)
- **Group Policy** - import the Microsoft Security Compliance Toolkit baseline GPOs or DISA's STIG GPO packages into a dedicated OU structure; restrict GPO edit rights to the change-authorized group. (3.4.2, 3.4.5)
- For Linux fleets, enforce with **Ansible** (CIS/STIG roles, including the official Red Hat STIG profiles via OpenSCAP remediation) or Chef/Puppet, keeping the playbooks in version control - the repo history doubles as change evidence. (3.4.2, 3.4.3)
- Verify continuously, not just at deployment: schedule CIS-CAT Pro, DISA SCC, or Defender for Endpoint's security-baseline assessment and track drift as findings. (3.4.2)

Change Control Board and Change Records

- Stand up a lightweight **CCB** - even at a 20-person shop, a weekly 15-minute review by IT lead + security lead satisfies the intent. Charter it in the configuration management policy: membership, quorum, what requires review, and the emergency-change path with after-the-fact review. (3.4.3)
- Run changes through a ticketing system - **Jira Service Management**, **ServiceNow**, **Freshservice**, or GitHub/Azure DevOps pull requests for infrastructure-as-code - so every change has a request, an approver who is not the requester, and an implementation record. (3.4.3)
- Define what counts as a change: firewall rules, GPO/Intune profile edits, new software, server builds, and baseline deviations all qualify; password resets and routine patching within an

approved patch window can be pre-approved as standard changes. (3.4.3)

Security Impact Analysis (3.4.4)

- Embed SIA into the change ticket as required fields, not a separate document: does the change affect CUI flows, authentication, logging, encryption, or the assessed boundary? Does it alter an SSP statement? A five-question checklist completed per change is sufficient and produces per-change evidence automatically. (3.4.4)
- Route changes flagged "security-impacting" to the security lead for sign-off before implementation, and test them in a staging tier or pilot ring (Intune deployment rings, GPO test OU) first. (3.4.4)
- When a change alters the boundary or a control implementation, update the SSP and network diagram as part of change closure - assessors trace recent changes to current documentation. (3.4.1, 3.4.4)

Access Restrictions for Change (3.4.5)

- Logical: only named members of the change-authorized groups (Domain Admins, Intune administrators, firewall admins) can modify production configuration; enforce via RBAC and PAM just-in-time elevation, and review membership quarterly. (3.4.5)
- Physical: lock server rooms and network closets; keep badge or key logs so physical change access is recorded alongside logical. (3.4.5)
- Alert on unauthorized change paths: GPO modifications (Event ID 5136), Intune profile changes (audit log), and firewall config changes should generate SIEM events reconciled against change tickets. (3.4.3, 3.4.5)

Least Functionality (3.4.6, 3.4.7)

- Strip the baseline: disable SMBv1, LLMNR/NetBIOS name resolution, legacy TLS 1.0/1.1, unneeded Windows optional features, and vendor bloatware; require PowerShell constrained language mode or logging for non-admins where feasible. (3.4.6)
- Maintain the ports/protocols/services list per system role (the DoD PPSM concept scaled down): a table of what is essential, on which systems, and why. Everything else is default-deny at the host firewall (Windows Defender Firewall via GPO/Intune) and the network firewall. (3.4.6, 3.4.7)
- Verify with scanning: an **Nmap** sweep or vulnerability-scanner port audit (Tenable Nessus, Qualys) compared against the approved list, on a schedule, with deltas investigated. (3.4.7)
- Disable or remove nonessential applications - preinstalled store apps, games, consumer sync clients - via Intune/GPO app removal and the application-control policy. (3.4.7, 3.4.8)

Application Control / Software Allowlisting (3.4.8)

- **Rev 2 gives a choice** - deny-by-exception (blocklist) or permit-by-exception (allowlist) - but allowlisting is the stronger posture and what assessors increasingly expect for CUI endpoints. (3.4.8)
- **AppLocker** - the accessible starting point on Windows Enterprise: publisher rules for signed software, path rules for managed install locations, audit mode first, then enforce; deploy via GPO or Intune. (3.4.8)
- **WDAC / App Control for Business** - stronger kernel-enforced control; use signed base policies with supplemental policies for line-of-business apps, and managed-installer rules so Intune-deployed software is auto-trusted. (3.4.8)
- Third-party allowlisting - **ThreatLocker**, **Airlock Digital**, **Ivanti Application Control** - trades license cost for far easier exception workflows and ringfencing; popular with DIB SMBs precisely because of 3.4.8. (3.4.8, 3.4.9)
- Keep the approved-software list as a living register (name, version policy, business owner, approval date) and forward block events to the SIEM - block logs are the cleanest enforcement evidence that exists for this control. (3.4.8)

Hardware and Software Inventory (Intune, Lansweeper, Asset Management)

- **Microsoft Intune** - enrolled-device hardware inventory and discovered-apps reporting cover the managed Windows/macOS/mobile fleet; export on a schedule. (3.4.1)
- **Lansweeper** - agentless network discovery that catches what MDM misses: servers, network devices, printers, IoT, and unmanaged endpoints; widely used as the authoritative asset system in the DIB mid-market. Alternatives: **NinjaOne**/RMM inventory, **Snipe-IT** (open-source asset register), **ServiceNow CMDB**. (3.4.1)
- Reconcile sources quarterly - Intune vs. Lansweeper vs. Entra ID device objects - and investigate unknowns; an asset that appears in discovery but not the inventory is both a 3.4.1 gap and a probable rogue device. (3.4.1)
- Track firmware and documentation in the baseline too: BIOS/UEFI versions (Lansweeper reports these), network-device OS versions, and the network diagram are all named in the requirement. (3.4.1)

Controlling User-Installed Software (3.4.9)

- Remove local administrator rights from standard users - the single control that makes 3.4.9 mostly moot - and elevate via endpoint privilege management (Intune EPM, AutoElevate, AdminByRequest) only for approved actions. (3.4.9)
- Offer a sanctioned path: the Intune **Company Portal** (or Winget-based catalogs) lets users self-install pre-approved titles without tickets or admin rights. (3.4.9)
- Monitor: alert or report on new entries in the discovered-apps inventory and reconcile against the approved-software register; with allowlisting enforced, unauthorized installs simply fail and

log. (3.4.8, 3.4.9)

Tools for Extracting Structured Configuration Evidence

Wherever possible, capture evidence as **structured, text-based exports** - JSON, XML, CSV, INF, XCCDF, or OSCAL - rather than screenshots. Machine-readable exports are timestamped, show the full setting, and can be ingested directly by a compliance platform.

SCAP & Benchmark Scanners (authoritative, structured)

- **DISA SCAP Compliance Checker (SCC)** with STIG benchmarks - per-host compliance results as XCCDF/OVAL/ARF XML; the canonical 3.4.2 verification artifact. (3.4.1, 3.4.2)
- **DISA STIG Viewer / Evaluate-STIG** - manual-check answers and automated results as CKL/CKLB (XML/JSON) checklists per system. (3.4.2)
- **CIS-CAT Pro** - CIS Benchmark assessment results as XML/CSV/HTML with per-setting pass/fail. (3.4.2)
- **OpenSCAP** (`oscap xccdf eval`) for Linux - results and remediation state as XCCDF/ARF XML. (3.4.2)
- **Microsoft Security Compliance Toolkit / PolicyAnalyzer** - compare deployed GPOs against the Microsoft baseline, exportable to XML/CSV; the deviation report doubles as your documented-deviations register. (3.4.1, 3.4.2)

Windows / Group Policy / Intune

- **Get-GPOReport -ReportType Xml** - every deployed baseline setting as XML; **gpresult /x** for the resultant set on a sample host. (3.4.2)
- **Microsoft Graph / Intune** (`deviceManagement/configurationPolicies` , `deviceCompliancePolicies`) - configuration profiles, security baselines, and per-device compliance state as JSON. (3.4.2)
- **Microsoft365DSC** - exports the full tenant configuration (Intune profiles included) as declarative, version-controllable text; diffing two exports is drift evidence. (3.4.1, 3.4.2, 3.4.3)
- **Get-AppLockerPolicy -Effective -Xml** and **citool.exe -lp** (WDAC) - the enforced application-control policy as XML; pair with AppLocker/CodeIntegrity block events (8004, 3077) exported from the event log. (3.4.8)
- **Get-WindowsOptionalFeature -Online** , **Get-Service** , and **Get-NetFirewallRule** - enabled features, running services, and host-firewall rules as CSV/JSON for least-functionality verification. (3.4.6, 3.4.7)

Inventory & Asset Data

- **Lansweeper** - asset reports (hardware, software, firmware versions) exported as CSV/XLSX or pulled via its API as JSON. (3.4.1)
- **Intune discovered apps / Graph** (`deviceManagement/detectedApps`) - per-device software inventory as JSON; schedule and diff exports to show new-install monitoring. (3.4.1, 3.4.9)
- **winget list / Get-Package** (Windows) and package-manager queries (`rpm -qa` , `dpkg -l`) - point-in-time software inventory as text for sampled hosts. (3.4.1, 3.4.9)
- **Snipe-IT / ServiceNow CMDB APIs** - the authoritative asset register as JSON/CSV where an asset system is in use. (3.4.1)

Network & Port Verification

- **Nmap** (`-oX`) - open-port scan results as XML, compared against the approved ports/protocols/services list. (3.4.6, 3.4.7)
- **Titania Nipper** and device-native config exports (`show running-config` , Palo Alto XML API) - network-device baseline compliance as XML/CSV/JSON. (3.4.1, 3.4.2)
- **Oxidized / RANCID** - automated network-config backup to text under version control; the commit history is change-tracking evidence for network devices. (3.4.1, 3.4.3)

Change-Control Evidence

- **Jira / ServiceNow APIs** - change tickets with approvals, SIA fields, and timestamps exported as JSON/CSV; a quarter's export demonstrates the process operates, not just exists. (3.4.3, 3.4.4)
- **Git history** - for infrastructure-as-code and Ansible-managed baselines, `git log` with pull-request approvals is native, structured change evidence. (3.4.3)

Cloud Posture (Azure, AWS, GCP)

- **Azure Policy / machine configuration** (`az policy state list -o json`) and **Microsoft Defender for Cloud** - baseline compliance state, including the built-in NIST SP 800-171 regulatory-compliance report. (3.4.1, 3.4.2)
- **AWS Config** (`aws configservice`) - resource configuration history and conformance-pack results as JSON; configuration *history* is drift/change evidence by design. (3.4.1, 3.4.3)
- **Prowler / ScoutSuite / Steampipe** - multi-cloud CIS/NIST configuration checks as JSON/CSV/HTML. (3.4.2)

OSCAL & Compliance Automation (the structured-format endgame)

- **OSCAL** (NIST Open Security Controls Assessment Language) - represent your SSP, components, and assessment results as JSON/XML/YAML. (all CM)
- **IBM compliance-trestle (Trestle)** - author and validate OSCAL artifacts programmatically. (all CM)

Practical tip: for every export, record what was run, on which system, and when. A traceable, dated artifact is worth far more than an undated screenshot.

Conclusion

Configuration Management rewards standardization: one named benchmark per platform deployed through one management plane, one change process with security impact analysis built into the ticket, one authoritative inventory reconciled on a schedule, and application control that turns "unauthorized software" from a policy statement into a blocked execution with a log entry. Do those four things and the six 5-point requirements largely verify themselves from the exports the tooling already produces.

The July 2026 suspension of CMMC Phase 2 paused the third-party certification milestone, not the underlying obligation: NIST SP 800-171, DFARS 252.204-7012, and the Level 2 self-assessment remain fully in force. Implementing this family well is still required today.

Glossary of Acronyms

AMI	Amazon Machine Image
ARF	Asset Reporting Format (SCAP results format)
CCB	Change Control Board
CIS	Center for Internet Security
CKL	STIG Viewer Checklist file format
CMDB	Configuration Management Database
CMMC	Cybersecurity Maturity Model Certification
CUI	Controlled Unclassified Information
DFARS	Defense Federal Acquisition Regulation Supplement
DIB	Defense Industrial Base
DISA	Defense Information Systems Agency
EPM	Endpoint Privilege Management
FIPS	Federal Information Processing Standard
GPO	Group Policy Object
MDM	Mobile Device Management

NIST	National Institute of Standards and Technology
OSCAL	Open Security Controls Assessment Language
OU	Organizational Unit (Active Directory)
PAM	Privileged Access Management
POA&M	Plan of Action and Milestones
PPSM	Ports, Protocols, and Services Management
RBAC	Role-Based Access Control
RMM	Remote Monitoring and Management
SCAP	Security Content Automation Protocol
SIA	Security Impact Analysis
SIEM	Security Information and Event Management
SMB	Server Message Block (protocol)
SPRS	Supplier Performance Risk System
SSP	System Security Plan
STIG	Security Technical Implementation Guide
TLS	Transport Layer Security
WDAC	Windows Defender Application Control (App Control for Business)
XCCDF	Extensible Configuration Checklist Description Format

About Methodical Security

Methodical Security provides resources and tooling to support Defense Industrial Base organizations through CMMC / NIST SP 800-171 assessments. Its platform, **Certalo**, works at the determination-statement level: it maps your existing documentation to each objective, flags where evidence is thin, and compresses the path to a submission-ready SSP, Assessment Report, and SPRS package. The result turns a one-time compliance scramble into a repeatable process — protecting current revenue and opening new contract eligibility.

